ÉCOLE MAROCAINE DES SCIENCES DE L'INGÉNIEUR

Campus Anfa : Casablanca

Filière : Ingénierie Informatique et Réseaux

Option : Cybersécurité, Infrastructure & Réponse aux Incidents (5CIRA - Groupe 3)

CAHIER DES CHARGES FONCTIONNEL & TECHNIQUE

Spécifications d'Ingénierie & Dossier de Cadrage Prévisionnel

Projet Uncloak

Système de Détection & de Blocage des Connexions C2 sous Windows

Sonde Hybride NDR / EDR de Chasse aux Canaux C2 Furtifs, Détection de Gigue par Forêt Aléatoire & Attribution Chirurgicale sous Windows

Équipe d'Élèves-Ingénieurs :

Oussama BELHANE
Ingénierie Système Win32 & Noyau Réseau

Otman SAADOUNI
Data Science, Pipeline ML & Datasets

Salah-Eddine KOUHAIL
Serveur Central, Cockpit SOC & Télémétrie

Encadrement Académique :

Département Cybersécurité
Équipe Pédagogique EMSI
Campus Anfa, Casablanca

Nature du Projet :
Projet de Fin d'Année (PFA 5CIRA)

Document de Référence Prévisionnelle : Rédigé selon les normes de gestion de projet d'ingénierie logicielle et de sécurité des systèmes d'information. Année Universitaire 2026 - 2027.

Table des matières

Résumé Exécutif du Projet **2**

1 Contexte Général, Problématique & Justification **2**
1.1 L'Évolution des Menaces Avancées (APT & Frameworks C2 Modernes) 2
1.2 Les Verrous Technologiques des Solutions Actuelles 2
1.3 Positionnement & Justification du Projet Uncloak 3

2 Définition des Objectifs & Périmètre du Projet (Scope) **3**
2.1 Objectif Général 3
2.2 Objectifs Spécifiques & Indicateurs Clés de Performance (KPI) 3
2.3 Périmètre du Projet (In-Scope & Out-of-Scope) 4

3 Analyse des Besoins Métier & Cas d'Usage Opérationnels **4**
3.1 Identification des Parties Prenantes 4
3.2 Cas d'Usage Clés (Use Cases) 5

4 Spécifications Fonctionnelles Détaillées (SF) **5**
4.1 SF-01 : Module de Capture Réseau & Filtrage BPF Haute Performance 5
4.2 SF-02 : Moteur d'Agrégation de Salves (Burst Aggregator) & Feature Engineering . . 6
4.3 SF-03 : Filtrage Cryptographique de Confiance & Anti-Domain Fronting 6
4.4 SF-04 : Moteur de Classification par Forêt Aléatoire (Random Forest) 6
4.5 SF-05 : Introspection Win32 & Protocole Early SYN-Cache 7
4.6 SF-06 : Moteur de Remédiation Active & Neutralisation Sécurisée 7
4.7 SF-07 : Télémétrie d'Entreprise & Journalisation Windows Native 7
4.8 SF-08 : Serveur Central de Flotte & Corrélation Multi-Hôtes 7
4.9 SF-09 : Cockpit de Supervision SOC (`uncloak-ui`) 7
4.10 SF-10 : Sous-Système d'Auto-Défense Endpoint & Résilience 8

5 Spécifications Non Fonctionnelles & Contraintes Techniques **8**
5.1 Performances & Empreinte Système (SNF-01) 8
5.2 Robustesse, Stabilité & Anti-BSOD (SNF-02) 8
5.3 Sécurité, Confidentialité & Conformité RGPD (SNF-03) 8
5.4 Maintenabilité & Qualité Logicielle (SNF-04) 9

6 Architecture Technique Cible & Justification des Choix **9**
6.1 Topologie Distribuée en 3 Niveaux 9
6.2 Matrice de Justification des Choix Technologiques 9

7 Organisation du Projet, Gouvernance & Répartition des Rôles **9**
7.1 Modèle de Gouvernance 9
7.2 Répartition Formelle des Responsabilités (Trinôme d'Élèves-Ingénieurs) 9

8 Planning Prévisionnel de Réalisation (Sprint sur 8 Semaines) **9**

9 Livrables Attendus & Protocole de Validation devant Jury **9**
9.1 Livrables Logiciels & Documentaires 9
9.2 Protocole de Démonstration en Direct (Scénario Live 30 Secondes) 13

10 Matrice de Gestion des Risques & Mesures de Contingence **13**

11 Conclusion & Engagement de Réalisation **13**

Résumé Exécutif du Projet

Présentation Générale du Projet

Le présent projet de fin d'année, intitulé **Uncloak**, aura pour objet la conception et l'implémentation d'une sonde de détection et de réponse de nouvelle génération combinant la surveillance réseau passive (**NDR** : *Network Detection and Response*) et l'introspection chirurgicale du système hôte (**EDR** : *Endpoint Detection and Response*).
La solution ciblera spécifiquement les communications malveillantes de type **Command and Control (C2)** furtives générées par des implants modernes (*Sliver, Havoc, Cobalt Strike*) opérant au travers de sessions chiffrées HTTPS (port 443) avec introduction de gigue temporelle (*jitter*) aléatoire. Le système atteindra cet objectif sans requérir de déchiffrement de contenu (préservant ainsi la conformité RGPD et la bande passante), tout en fournissant une attribution instantanée au Process ID (PID) Windows et une neutralisation chirurgicale via l'API noyau `SetTcpEntry` garantissant l'absence totale de crash système (zéro BSOD).

1 Contexte Général, Problématique & Justification

1.1 L'Évolution des Menaces Avancées (APT & Frameworks C2 Modernes)

Dans le cadre des attaques ciblées contemporaines (menaces persistantes avancées, groupes cybercriminels et opérations de rançongiciel), la phase post-exploitation repose quasi systématiquement sur l'établissement d'un canal de communication furtif entre la machine compromise et l'infrastructure de l'attaquant. Pour maintenir leur accès et exécuter des commandes interactives, les adversaires déploient des agents de commande et contrôle issus de frameworks modernes tels que **Sliver**, **Havoc**, **Cobalt Strike** ou **Mythic**.

Ces canaux de communication établissent un balisage périodique (*beaconing*) vers l'extérieur. L'enjeu stratégique pour une équipe défensive (Blue Team / SOC) réside dans l'interception de ces balises dès les premières minutes suivant l'intrusion, avant toute phase de mouvement latéral ou d'exfiltration de données sensibles.

1.2 Les Verrous Technologiques des Solutions Actuelles

Les Centres Opérationnels de Sécurité (SOC) font face à une crise de visibilité majeure provoquée par trois facteurs convergents :

1. **Généralisation du Chiffrement TLS 1.3 :** Les communications sortantes utilisent le port HTTPS standard (TCP 443). Les systèmes de détection d'intrusion réseau traditionnels (NIDS basés sur les signatures de contenu tels que Snort ou Suricata) sont aveugles sur la charge utile chiffrée. L'inspection avec déchiffrement TLS (SSL Interception) est complexe à maintenir, dégrade drastiquement les performances et se heurte au *Certificate Pinning*.
2. **Évasion par Gigue Temporelle Aléatoire (Jitter) :** Pour neutraliser les règles élémentaires des SIEM basées sur des intervalles fixes (par exemple : une alerte si un paquet est émis toutes les 30 secondes), les balises C2 introduisent un jitter stochastique (ex : 30s ±30%, soit des intervalles oscillant entre 21s et 39s). Les flux malveillants deviennent statistiquement indiscernables d'une navigation web ordinaire par de simples heuristiques linéaires.
3. **Déconnexion Structurelle entre Télémétrie Réseau et Système Hôte :** Une sonde réseau périphérique observe des adresses IP et des ports, mais ignore quel exécutable ou processus a généré la trame sur le poste client. Inversement, les agents EDR classiques sont souvent lourds, dépendants du cloud pour l'inférence, et procèdent à des arrêts brutaux de processus (`taskkill`

`/F`) qui provoquent des écrans bleus (BSOD) si la charge malveillante est injectée dans un service partagé tel que `svchost.exe` ou `lsass.exe`.

Outil Conventionnel	Mécanisme de Détection	Angle Mort Opérationnel
NIDS à Signatures (Snort, Suricata)	Analyse textuelle de la charge utile (regex, signatures hexadécimales).	Inopérant sur le trafic chiffré HTTPS sans interception man-in-the-middle.
SIEM Traditionnel (Règles statiques)	Seuils arithmétiques et périodicité temporelle fixe.	Aveugle face aux distributions temporelles à gigue aléatoire (Jitter C2).
EDR Conventionnel (Focalisé binaire)	Surveillance d'appels API locaux et signatures sur disque.	Faible corrélation en temps réel avec la dynamique fine des flux réseau.

TABLE 1 – Comparatif des limites des outils défensifs conventionnels.

1.3 Positionnement & Justification du Projet Uncloak

Le projet **Uncloak** aura pour mission de surmonter ces verrous en développant une sonde hybride capable de :

— Analyser le rythme temporel des échanges réseau de manière passive, sans altérer ni déchiffrer les paquets.

— Identifier avec certitude statistique la présence d'une balise grâce à un modèle d'intelligence artificielle léger (**Forêt Aléatoire / Random Forest**) entraîné sur des comportements réels.

— Interroger instantanément la table TCP du noyau Windows (`iphlpapi.dll`) pour identifier le Process ID (PID) et l'arborescence binaire du programme émetteur.

— Neutraliser chirurgicalement la connexion au niveau de la couche transport via l'API `SetTcpEntry`, garantissant l'interruption du pirate sans provoquer de crash système.

2 Définition des Objectifs & Périmètre du Projet (Scope)

2.1 Objectif Général

L'objectif du projet consistera à concevoir, développer, déployer et valider une architecture logicielle modulaire en 3 tiers assurant la détection précoce, l'attribution système et la remédiation active des canaux de balisage C2 chiffrés sur un parc d'endpoints Windows Active Directory.

2.2 Objectifs Spécifiques & Indicateurs Clés de Performance (KPI)

Le système développé devra respecter rigoureusement les exigences quantifiables suivantes :

1. **Délai Maximal de Détection :** Le système devra détecter et qualifier un flux de balisage C2 actif en moins de **15 secondes** (soit au terme de 6 à 8 salves consécutives d'observation).
2. **Précision Algorithmique :** Le modèle de classification prédictive devra atteindre une métrique **PR-AUC (Precision-Recall Area Under Curve) supérieure à 0.95** et une métrique **ROC-AUC supérieure à 0.98** sur les jeux de données de test.
3. **Taux de Faux Positifs :** Le taux de faux positifs devra être maintenu strictement en dessous de **1.0%** sous trafic bureautique réel (incluant Teams, Slack, Edge, Outlook et Windows Update).
4. **Vitesse d'Inférence :** La latence d'inférence de la classification d'un flux par le modèle Random Forest devra être inférieure à **1.0 milliseconde** sur un processeur standard.

5. **Empreinte Ressource Endpoint :**
   — Consommation mémoire vive (RAM) de l'agent local inférieure à **15 Mo**.
   — Charge processeur (CPU) moyenne de l'agent inférieure à **1.0%**.
6. **Stabilité et Sécurité de Remédiation :** Le système devra garantir un taux de **0% d'écrans bleus (BSOD)** lors des phases de neutralisation chirurgicale.

2.3 Périmètre du Projet (In-Scope & Out-of-Scope)

Éléments Inclus (In-Scope)

— Capture passive et découpage en flux des connexions sortantes TCP (notamment ports 80, 443, 8080, 8443) et surveillance des requêtes DNS associées.
— Prise en charge des environnements cibles sous **Windows 10 (x64)**, **Windows 11 (x64)** et **Windows Server 2022**.
— Filtrage noyau haute performance via le pilote Npcap avec filtre BPF compilé et troncature de trame (*Snaplen*) fixée à 96 octets.
— Extraction de caractéristiques statistiques : moyenne temporelle, écart-type, coefficient de variation du jitter, entropie de Shannon de la charge utile et empreinte client TLS JA4.
— Corrélation noyau Socket vers PID via l'API Win32 native `GetExtendedTcpTable` et implémentation du protocole *Early SYN-Cache* pour intercepter les sockets éphémères de durée inférieure à 150 ms.
— Remédiation chirurgicale sans BSOD via l'API `SetTcpEntry` révoquant le socket TCP sans terminer le processus hôte.
— Serveur central (`uncloak-manager`) assurant l'agrégation de flotte, la corrélation multi-hôtes de campagnes C2 et la persistence SQLite en mode WAL.
— Console opérateur SOC (`uncloak-ui`) offrant une matrice de flotte par tiers Active Directory, un graphe vectoriel SVG interactif et un panneau forensique d'investigation.
— Mécanismes d'auto-défense endpoint : modification des DACL du processus de l'agent et supervision croisée par Watchdog jumelé.

Éléments Exclus (Out-of-Scope)

— Déchiffrement dynamique MitM des flux chiffrés par injection de certificats d'autorité racine.
— Développement d'un pilote noyau Windows Ring 0 personnalisé (fichiers `.sys` non signés nécessitant le mode Testsigning de Windows).
— Prise en charge des systèmes Linux ou macOS pour l'attribution noyau (le périmètre prioritaire étant l'infrastructure Active Directory d'entreprise).
— Détection des canaux de stéganographie pure ou de tunneling ICMP brut (réservés à la feuille de route post-PFA).

3 Analyse des Besoins Métier & Cas d'Usage Opérationnels

3.1 Identification des Parties Prenantes

Le système devra répondre aux exigences opérationnelles de 4 catégories d'acteurs :

1. **Analyste SOC (N1 / N2) :** Doit visualiser en temps réel l'état de sécurité de la flotte, identifier immédiatement les endpoints affichant un score de risque critique, inspecter les flux anormaux et déclencher des actions d'investigation.

2. **Chasseur de Menaces / Forensique (Threat Hunter / DFIR) :** Doit pouvoir accéder à la lignée complète du processus suspect (PID, binaire, processus parent PPID), visualiser les métriques temporelles fines (gigue, salves) et analyser les corrélations de campagnes entre plusieurs machines.
3. **Administrateur Sécurité / Déploiement :** Doit pouvoir installer l'agent de manière transparente sur les machines du parc, administrer les règles de confiance (listes blanches SNI/ASN) et auditer l'intégrité de la solution.
4. **L'Hôte Windows (Composant Automate) :** Doit maintenir la capture locale, exécuter les contrôles de filtrage, préserver son intégrité face aux tentatives de désactivation et neutraliser les connexions malveillantes en mode automatique ou semi-automatique.

3.2 Cas d'Usage Clés (Use Cases)

Réf.	Titre du Cas d'Usage	Acteur	Description Opérationnelle
UC-01	Détection de balisage avec gigue	Agent / ML	Écoute passive du flux sortant, calcul du coefficient de variation et classification par le modèle Random Forest.
UC-02	Attribution Socket vers PID	Agent local	Interrogation de la table TCP MIB-II dès le paquet SYN et mise en cache précoce de l'identité du processus.
UC-03	Neutralisation chirurgicale	Analyste / Agent	Réception d'un ordre de coupure et réinitialisation de la session TCP via `SetTcpEntry` sans crash système.
UC-04	Investigation forensique	Analyste SOC	Consultation du cockpit opérateur, analyse de l'arborescence des processus et des graphiques de gigue.
UC-05	Corrélation multi-hôtes	Serveur central	Regroupement automatique des machines infectées communiquant vers la même infrastructure distante C2.

TABLE 2 – Matrice des cas d'usage opérationnels du système.

4 Spécifications Fonctionnelles Détaillées (SF)

Le système comportera 10 exigences fonctionnelles majeures réparties entre la capture réseau, le pipeline de données, l'introspection système et la console centrale.

4.1 SF-01 : Module de Capture Réseau & Filtrage BPF Haute Performance

— Le système devra s'interfacer avec le pilote de capture **Npcap** sur l'interface réseau active de chaque machine surveillée.

— Le système devra injecter un filtre **BPF (Berkeley Packet Filter)** au niveau du pilote noyau afin d'éliminer le bruit local avant tout transfert vers l'espace utilisateur :

```
tcp and (((ip[2:2] - ((ip[0]&0xf)<<2)) - ((tcp[12]&0xf0)>>2)) != 0) and not (
    dst net 10.0.0.0/8 or dst net 192.168.0.0/16 or dst net 172.16.0.0/12)
```

— La taille de capture maximale (*Snaplen*) devra être strictement bornée à **96 octets**, capturant uniquement les en-têtes Ethernet, IP, TCP et le début du handshake TLS, interdisant formellement l'interception de données privées d'utilisateurs.

— Le module devra implémenter une file d'attente circulaire découplée (*ring buffer*) pour éviter tout blocage de la boucle de capture réseau par les threads d'analyse.

4.2 SF-02 : Moteur d'Agrégation de Salves (Burst Aggregator) & Feature Engineering

— Le système devra agréger l'ensemble des paquets consécutifs d'une même session séparés de moins de **200 millisecondes** au sein d'une unique entité nommée **Salve Applicative (Burst)**.

— L'intervalle inter-balise (Δt) devra être rigoureusement calculé entre les timestamps de début de deux salves consécutives :

$$\Delta t_i = t_{burst}(i) - t_{burst}(i-1) \tag{1}$$

— Pour chaque session de flux, le système devra calculer un vecteur de 7 caractéristiques statistiques normalisées :

1. $\mu_{\Delta t}$: Moyenne arithmétique des temps de repos.
2. $\sigma_{\Delta t}$: Écart-type des intervalles temporels.
3. CV : **Coefficient de Variation** ($CV = \frac{\sigma_{\Delta t}}{\mu_{\Delta t}}$), mesurant la gigue relative indépendamment du temps de sommeil absolu.
4. IQR : Écart interquartile ($IQR = Q_3 - Q_1$) de la taille en octets des salves, résilient au padding aléatoire.
5. $R_{payload}$: Ratio des paquets applicatifs utiles par rapport au volume total en excluant les acquittements TCP purs (ACK de 54 octets).
6. $H(X)$: Entropie de Shannon de la charge utile (score normalisé entre 0.00 et 8.00).
7. $R_{out/in}$: Ratio volumétrique entre octets transmis et reçus pour distinguer navigation standard et exfiltration.

4.3 SF-03 : Filtrage Cryptographique de Confiance & Anti-Domain Fronting

— Le système devra inspecter l'extension **SNI (Server Name Indication)** du paquet TLS `Client Hello`.

— Le système devra confronter le nom de domaine déclaré à une liste blanche d'éditeurs vérifiés (Microsoft, Slack, Zoom, Google Cloud, CDN certifiés).

— Le système devra implémenter une vérification croisée obligatoire : si un flux déclare un domaine appartenant à un éditeur officiel, le système vérifiera que l'adresse IP de destination appartient bien au Système Autonome (**ASN**) de cet éditeur. Tout écart sera qualifié de tentative de falsification ou de *Domain Fronting*.

4.4 SF-04 : Moteur de Classification par Forêt Aléatoire (Random Forest)

— Le système devra intégrer un modèle de classification entraîné selon l'algorithme de Forêt Aléatoire (*Random Forest*) sous Scikit-Learn.

— Le modèle sera entraîné sur un jeu de données hybride associant le benchmark international **CTU-13** (scénarios TrickBot, Neris, Virut) et des captures de laboratoire récentes simulant des sessions de balisage Sliver et Havoc avec des gigues variant de 0% à 70%.

— Les probabilités brutes devront être calibrées par régression isotonique (`CalibratedClassifierCV`) pour générer un score de menace fiable entre 0.0% et 99.9%.

— Le seuil d'alerte opérationnelle sera fixé à **0.85** afin d'interdire les faux positifs sur le parc.

— Le système intégrera le framework **SHAP (TreeExplainer)** pour expliciter les trois caractéristiques mathématiques ayant déclenché l'alerte sur un flux donné.

4.5 SF-05 : Introspection Win32 & Protocole Early SYN-Cache

— Le système devra appeler l'API système native `GetExtendedTcpTable` exportée par la bibliothèque Windows `iphlpapi.dll` en utilisant l'option `TCP_TABLE_OWNER_PID_ALL`.

— Pour résoudre la course critique des balises éphémères (sessions C2 ouvertes et refermées en moins de 150 ms), le système devra appliquer le protocole **Early SYN-Cache** :

1. Dès l'interception du paquet initial TCP SYN, la table TCP sera interrogée.
2. Le quadruplet `(Port Local, IP Distante, Port Distant)` sera associé au PID et stocké dans un cache mémoire LRU doté d'une durée de rétention de 180 secondes.
3. Lorsque le verdict du modèle ML sera rendu plusieurs secondes après, l'identité du processus sera immédiatement récupérée depuis le cache même si le socket a déjà disparu de l'OS.

— Le système devra extraire le chemin complet de l'exécutable sur le disque (`QueryFullProcessImageNameW`) et identifier le processus parent (PPID) via `CreateToolhelp32Snapshot`.

4.6 SF-06 : Moteur de Remédiation Active & Neutralisation Sécurisée

— Le système devra proposer 4 actions de réponse graduée :

1. **Coupure Chirurgicale de Socket :** Appel de l'API Win32 `SetTcpEntry` avec passage de l'état `MIB_TCP_STATE_DELETE_TCB`. Cette action force le noyau Windows à émettre un segment TCP RST vers l'attaquant et à désallouer le socket sans terminer le processus.
2. **Ralentissement TCP (Tarpit) :** Injection volontaire de délai d'acquittement pour étouffer le débit de communication du malware.
3. **Terminaison d'Arborescence :** Réservée exclusivement aux binaires non signés et non critiques pour le système d'exploitation.
4. **Journalisation Silencieuse :** Mode d'observation pure sans action de blocage.

4.7 SF-07 : Télémétrie d'Entreprise & Journalisation Windows Native

— Le système devra générer des événements structurés dans le journal d'événements Windows natif (*Windows Event Log*) sous la source `Uncloak` :

  — **Event ID 9001 :** Notification informative d'attribution de flux suspect.
  — **Event ID 9002 :** Alerte critique confirmant la neutralisation effective d'un canal C2 actif avec horodatage, PID, exécutable et score IA.

— Le système proposera un connecteur optionnel d'exportation au format standard **OCSF / JSON** via Webhook asynchrone vers les collecteurs de logs d'entreprise.

4.8 SF-08 : Serveur Central de Flotte & Corrélation Multi-Hôtes

— Le composant serveur (`uncloak-manager`) devra gérer les connexions simultanées d'au moins 32 agents au travers de canaux WebSocket sécurisés chiffrés en mTLS (port 8443).

— Le serveur devra assurer la corrélation multi-hôtes en regroupant sous un identifiant de campagne unique l'ensemble des endpoints communiquant vers la même adresse IP ou présentant une empreinte TLS JA4 identique.

— L'ensemble des événements, alertes et actions de remédiation sera persisté dans une base de données locale transactionnelle **SQLite en mode WAL (Write-Ahead Logging)**.

4.9 SF-09 : Cockpit de Supervision SOC (`uncloak-ui`)

— Le système devra intégrer une interface web moderne et réactive articulée autour de 3 vues :

1. **Fleet Threat Matrix :** Tableau de bord de la flotte ordonné selon les tiers Active Directory (Tier 0 Contrôleurs de domaine, Tier 1 Serveurs Applicatifs, Tier 2 Postes de travail) affichant l'état de santé, la consommation des ressources et le niveau de risque.
2. **Graphe Topologique Vectoriel (SVG) :** Visualisation interactive reliant l'infrastructure attaquante, le Patient Zéro infecté et les machines atteintes par mouvement latéral.
3. **Console Forensique Drill-Down :** Panneau d'investigation détaillée par hôte comportant l'arborescence des processus, les courbes d'intervalles Δt, les valeurs SHAP et les commandes de neutralisation en un clic.

4.10 SF-10 : Sous-Système d'Auto-Défense Endpoint & Résilience

— La sonde devra modifier au démarrage son propre descripteur de sécurité (**DACL**) via l'appel `SetKernelObjectSecurity` afin de retirer explicitement les droits `PROCESS_TERMINATE`, `PROCESS_VM_WRITE` et `PROCESS_SUSPEND_RESUME`, interdisant la fermeture du processus de sécurité même par un Administrateur local.

— Le système déploiera une architecture de **Watchdog jumelé** à deux processus s'observant mutuellement (`WaitForSingleObject`) : l'interruption de l'un entraîne la relance immédiate par l'autre en moins de 1 seconde.

— En cas de rupture réseau avec le serveur central, l'agent devra basculer en mode autonome et enregistrer localement ses alertes dans un tampon SQLite chiffré par HMAC.

5 Spécifications Non Fonctionnelles & Contraintes Techniques

5.1 Performances & Empreinte Système (SNF-01)

— **Charge Processeur :** La consommation CPU de l'agent ne devra pas dépasser **1.0%** en régime nominal, même sous un trafic réseau soutenu de 500 Mbps.

— **Mémoire Vive :** L'empreinte mémoire résidente (Working Set) de la sonde ne devra pas excéder **15 Mo**.

— **Latence de Détection :** Le calcul du score de menace devra être délivré en moins de **1.0 milliseconde** après l'achèvement de la fenêtre d'observation.

5.2 Robustesse, Stabilité & Anti-BSOD (SNF-02)

— **Zero Crash Système :** Le système ne devra jamais provoquer d'écran bleu ou d'instabilité du système d'exploitation Windows hôte lors de la remédiation.

— **Gestion des Erreurs ctypes :** Tous les appels vers l'API Win32 devront être protégés par des blocs de capture d'exceptions stricts pour parer aux fuites mémoire.

— **Débrayage d'Urgence (Dead-Man Switch) :** Un mécanisme de désactivation d'urgence à distance validé par jeton cryptographique HMAC SHA-256 devra permettre la neutralisation immédiate de la sonde en cas de conflit opérationnel.

5.3 Sécurité, Confidentialité & Conformité RGPD (SNF-03)

— **Confidentialité des Données Utilisateurs :** Aucune donnée applicative transmise par l'utilisateur ne sera interceptée ni stockée (inspection bornée à 96 octets d'en-tête).

— **Chiffrement des Canaux Internes :** Les flux télémétriques entre les sondes et le gestionnaire central devront être authentifiés et chiffrés en TLS 1.3 / mTLS.

5.4 Maintenabilité & Qualité Logicielle (SNF-04)

— **Typage Statique Strict :** L'intégralité du code source Python devra respecter le standard de typage statique `mypy` et utiliser des classes de données immuables `pydantic`.

— **Couverture de Tests Automatisés :** Le projet devra maintenir une suite de tests unitaires et de validation d'intégration sous `pytest` couvrant l'extraction de métriques et la conformité des structures ctypes.

6 Architecture Technique Cible & Justification des Choix

6.1 Topologie Distribuée en 3 Niveaux

L'architecture de la solution sera découpée en 3 niveaux fonctionnels :

Schéma d'Architecture en 3 Niveaux

— **Niveau 1 : Sondes Endpoints (`uncloak-agent`)** Exécutées en tâche de fond sur chaque machine du parc. Assurent la capture passive Npcap (Snaplen 96 octets), l'Early SYN-Cache, la corrélation Win32 Socket vers PID et la coupure chirurgicale via `SetTcpEntry`.

— **Niveau 2 : Serveur Gestionnaire de Flotte (`uncloak-manager`)** Point central d'ingestion WebSocket mTLS (port 8443). Assure l'agrégation multi-machines, la corrélation des campagnes C2, l'évaluation par le modèle Random Forest calibré et la persistence SQLite WAL.

— **Niveau 3 : Console Opérateur SOC (`uncloak-ui`)** Interface web interactive (port 8080) offrant la matrice de risque ordonnée selon les tiers Active Directory, le graphe d'attaque vectoriel SVG et le cockpit d'investigation forensique.

6.2 Matrice de Justification des Choix Technologiques

7 Organisation du Projet, Gouvernance & Répartition des Rôles

7.1 Modèle de Gouvernance

Le projet sera conduit selon une méthode agile adaptée au calendrier académique du PFA 5CIRA (sprints de 2 semaines, réunions hebdomadaires obligatoires de 15 minutes avec l'encadrant académique et revues d'ingénierie régulières).

7.2 Répartition Formelle des Responsabilités (Trinôme d'Élèves-Ingénieurs)

Les rôles techniques au sein de l'équipe sont strictement étanchés pour garantir une progression fluide et sans interférence :

8 Planning Prévisionnel de Réalisation (Sprint sur 8 Semaines)

9 Livrables Attendus & Protocole de Validation devant Jury

9.1 Livrables Logiciels & Documentaires

1. **Livrables Logiciels :**
   — Code source intégralement modulaire du package `uncloak` structuré en dossiers spécialisés (`core`, `agent`, `manager`, `detection`, `mitigation`, `ui`).
   — Exécutable installable de l'agent endpoint sous environnement Windows.

Choix Retenu	Alternative Écartée	Justification de l'Arbitrage Technique
Python 3.12 + ctypes Win32	C++ Natif Pur	Vitesse de développement optimale pour un projet d'ingénierie, intégration directe de l'écosystème Scikit-Learn et appels directs aux API noyau (`iphlpapi.dll`) avec un surcoût d'appel inférieur à 2 microsecondes.
Forêt Aléatoire (Random Forest)	Réseaux Profonds (LSTM / Deep Learning)	Un LSTM requiert un GPU lourd, induit une latence élevée et constitue une boîte noire inacceptable en investigation. La Forêt Aléatoire s'exécute en moins de 1 ms sur CPU standard et permet une explicabilité locale par SHAP.
Snaplen de 96 octets (Npcap)	Capture PCAP Complète	Une capture complète sature rapidement le disque dur et la bande passante, en plus de violer le RGPD. 96 octets capturent 100% des en-têtes utiles sans jamais enregistrer de contenu privé.
API `SetTcpEntry`	Terminaison `taskkill /F`	Si le malware est injecté dans un processus partagé (`svchost.exe`, `lsass.exe`), tuer le processus provoque un arrêt brutal de Windows (BSOD). `SetTcpEntry` détruit uniquement le socket réseau malveillant sans altérer le processus.
WebSockets Bidirectionnels mTLS	Polling HTTP REST	Le polling périodique surcharge le réseau. Un tunnel WebSocket permanent permet au serveur d'acheminer un ordre de neutralisation en moins de 10 ms dès la confirmation de la menace.
SQLite en mode WAL	Elasticsearch / MongoDB	Élimine la dépendance envers un serveur de base de données lourd. Le mode WAL permet des écritures haut débit sans verrouillage de table avec une consommation RAM inférieure à 5 Mo.

Table 3 – Matrice d'arbitrage et de justification des choix technologiques.

Élève-Ingénieur	Rôle Fonctionnel	Modules & Tâches Attribués
Oussama BELHANE	Ingénierie Système Windows, Réseau Bas Niveau & Noyau	— Moteur de capture Npcap et filtre BPF. — Interfaçage Win32 (`iphlpapi.dll`, `GetExtendedTcpTable`). — Protocole Early SYN-Cache (sockets éphémères). — Actionneur de coupure chirurgicale (`SetTcpEntry`). — Mécanismes d'auto-défense (DACL & Watchdog).
Otman SAADOUNI	Data Science, Pipeline Machine Learning & Datasets	— Nettoyage du benchmark CTU-13. — Génération du dataset de laboratoire moderne (Sliver). — Moteur de calcul de gigue (CV, IQR, salves). — Entraînement et calibrage du modèle Random Forest. — Évaluation PR-AUC, ROC-AUC et intégration SHAP.
Salah-Eddine KOUHAIL	Serveur Central, Console Opérateur SOC & Télémétrie	— Serveur gestionnaire de flotte (`uncloak-manager`). — Moteur de corrélation multi-hôtes et campagnes. — Interface web opérateur (`uncloak-ui`) et graphe SVG. — Modélisation de la base transactionnelle SQLite. — Télémétrie native Windows Event Log (9001/9002).

TABLE 4 – Répartition formelle des responsabilités au sein du trinôme PFA.

Semaine	Phase du Projet	Activités Techniques Prévisionnelles	Livrables Intermédiaires
S1 - S2	Cadrage, Datasets & Pipeline ML Initial	Ingestion du benchmark CTU-13, extraction des deltas temporels, premier entraînement Random Forest et déploiement d'un listener C2 de test.	Dataset normalisé, premier modèle `c2_model.pkl` et rapport préliminaire.
S3 - S4	Capture Réseau & Feature Engineering	Développement du sniffer Npcap, filtrage BPF noyau, découpage en salves (<200ms) et filtre cryptographique de confiance SNI/ASN.	Module `sniffer.py`, extracteur `stats.py` et tests de charge réseau.
S5 - S6	Introspection Win32, Mitigation & Cockpit	Intégration de `GetExtendedTcpTable`, Early SYN-Cache, actionneur `SetTcpEntry` anti-BSOD et interface SOC réactive.	Module `win32_sockets.py`, actionneur `sever.py` et console `uncloak-ui`.
S7	Intégration Globale & Auto-Défense	Raccordement de bout en bout Agent - Manager - Dashboard, mécanismes anti-tampering (DACL, Watchdog) et tests face à Sliver C2.	Version Release Candidate, matrice des benchmarks et journal d'audit SQLite.
S8	Répétition Soutenance & Dossier Final	Répétition chronométrée de la démonstration live (30s), finalisation du Dossier d'Architecture Technique (DAT) et slides de présentation.	Dossier PFA complet finalisé et environnement de démo validé.

TABLE 5 – Planning prévisionnel de réalisation structuré en 5 phases.

— Modèle de classification Random Forest calibré et sérialisé (`c2_model.pkl`).
— Suite de tests automatisés sous `pytest` validant les modules critiques.

2. **Livrables Documentaires Académiques :**
— Le présent Cahier des Charges Fonctionnel et Technique (CdC-FT).
— Le Dossier d'Architecture Technique officiel (DAT PFA 5CIRA).
— Le Rapport Final de Projet de Fin d'Année conforme à la charte EMSI.
— Le Guide de Déploiement et Manuel d'Exploitation pour les équipes SOC.

9.2 Protocole de Démonstration en Direct (Scénario Live 30 Secondes)

La validation pratique devant le jury académique EMSI s'articulera autour d'une démonstration opérationnelle de 30 secondes chronométrée et reproductible :

Scénario Opérationnel de la Démonstration Live

1. **État Initial :** La console `uncloak-ui` affiche la flotte Active Directory avec des indicateurs de santé nominaux (vert). Un serveur C2 de test est en attente sur une infrastructure distante (port 443).
2. **Déclenchement de l'Attaque :** Exécution sur le poste de démonstration d'un implant de test simulant une balise C2 avec un temps de sommeil de 10 secondes et un jitter de 30% vers le serveur externe.
3. **Réaction Automatique dÚncloak (moins de 15 secondes) :**
— L'agent local intercepte les salves chiffrées et l'Early SYN-Cache identifie immédiatement le binaire source et son PID.
— Le modèle Random Forest classe le flux avec une certitude statistique supérieure à 95%.
— L'alerte clignote en rouge sur la console SOC avec l'arborescence du processus et la campagne corrélée.
— L'agent exécute l'ordre de destruction de socket via `SetTcpEntry`.
4. **Constat Immédiat devant le Jury :**
— Le serveur d'attaque externe cesse immédiatement de recevoir les balises (canal C2 coupé net).
— La machine de présentation ne subit aucun ralentissement ni arrêt inopiné (zéro BSOD). Les applications bureautiques et services système continuent de fonctionner sans interruption.

10 Matrice de Gestion des Risques & Mesures de Contingence

11 Conclusion & Engagement de Réalisation

Le présent cahier des charges fonctionnel et technique formalise les exigences scientifiques, logicielles et opérationnelles présidant à la réalisation du projet **Uncloak**.

L'équipe d'élèves-ingénieurs s'engage à respecter rigoureusement les spécifications formulées, les normes de qualité logicielle, les contraintes de sécurité et le calendrier des jalons hebdomadaires afin de délivrer une solution de cyberdéfense hybride de niveau industriel pour la soutenance finale du cursus 5CIRA de l'EMSI Casablanca.

Risque Technique Identifié	Gravité	Probabilité	Mesure d'Atténuation & Plan de Repli
Faux Positifs sur Outils Collaboratifs (Teams, Slack)	Élevée	Moyenne	Validation croisée cryptographique obligatoire : exclusion des flux vers les éditeurs certifiés uniquement si l'adresse IP de destination appartient à l'ASN officiel déclaré de l'éditeur.
Course Critique sur Connexions Éphémères (<150ms)	Élevée	Élevée	Déploiement du protocole Early SYN-Cache : interrogation de la table TCP dès le premier paquet SYN et mise en cache LRU en mémoire durant 180 secondes.
Surcharge Processeur sous Fort Trafic Réseau	Élevée	Moyenne	Application du filtre BPF compilé directement dans le pilote Npcap en espace noyau et troncature stricte des trames à 96 octets pour diviser le débit mémoire par 10.
Instabilité Système lors de la Remédiation	Critique	Faible	Interdiction stricte d'exécuter des arrêts de processus aveugles (`taskkill /F`). Utilisation exclusive de la réinitialisation de socket via l'API `SetTcpEntry`.
Désactivation de la Sonde par un Attaquant Local	Élevée	Faible	Verrouillage des descripteurs de sécurité DACL (suppression des droits de terminaison) et déploiement d'un processus superviseur Watchdog assurant une relance en 1 seconde.

TABLE 6 – Matrice d'analyse des risques et plans de contingence.

Fait à Casablanca, le 10 Novembre 2026

Pour l'équipe projet Uncloak :

Oussama BELHANE | Otman SAADOUNI | Salah-Eddine KOUHAIL